

LAPORAN RESMI AUDIT & PEMINDAIAN KEAMANAN SIBER

Kepada Yth.

Direksi Teknis dan Tim Keamanan Informasi

Mitra Korporasi Internasional & Domestik

1. Informasi Dokumen & Penulis

Disusun Oleh	Habib Muzakki (Habib) Alumni Kelas 12 Agama, MAN 2 Kota Serang Mahasiswa D4 Vokasi Teknik Informatika, Harkat Negeri Tegal Spesialisasi: Pemula Keamanan Siber & Bug Hunter (Bug Bounty)
Tanggal Pembuatan	Sabtu, 18 Juli 2026, 17:09:44 WIB
Perangkat Penguji	Zed Attack Proxy (ZAP) Versi 2.17.0 (Powered by Checkmarx)
Klasifikasi Dokumen	Formal / Sangat Rahasia (Strictly Confidential)

2. Ringkasan Eksekutif (Executive Summary)

Laporan ini menyajikan hasil evaluasi keamanan otomatis terstruktur yang dilakukan pada infrastruktur digital tertera menggunakan ZAP oleh Checkmarx. Tujuan utama dari audit ini adalah untuk mengidentifikasi celah keamanan aktif (vulnerabilities) serta kesalahan konfigurasi (misconfigurations) yang berpotensi dieksploitasi oleh pihak ketiga yang tidak bertanggung jawab. Evaluasi ini mencakup deteksi ancaman tingkat tinggi hingga analisis informasi permukaan.

Statistik Temuan (Alerts Summary)

Tingkat Risiko	Jumlah Temuan	Status Validasi
TINGGI (HIGH)	2	Terkonfirmasi Aktif
SEDANG (MEDIUM)	2	Sistemik (Konfigurasi Global)
LEMAH (LOW)	7	Membutuhkan Pengetatan
INFORMASI (INFO)	7	Analisis Arsitektur / Jejak Log
Positif Palsu (False Positives)	0	Validitas 100%

| 3. Detail Analisis Celah Keamanan (Vulnerability Breakdown)

TINGGI SQL Injection

Deskripsi Celah	Aplikasi memungkinkan manipulasi parameter input pengguna untuk memodifikasi struktur query database pada server. Ini membuka peluang pencurian data sensitif atau pengambilalihan hak akses database secara penuh.
URL Target	https://google-gruyere.appspot.com/.../login?pw=ZAP&uid=ZAP+AND+1%3D1++ https://google-gruyere.appspot.com/.../saveprofile?action=new&is_author=True&pw=ZAP&uid=ZAP+AND+1%3D1++
Parameter & Metode	uid (Metode: GET)
Pola Serangan (Vector)	ZAP AND 1=1 -- serta ZAP AND 1=2 --
Bukti (Evidence)	Hasil respons halaman termanipulasi penuh secara Boolean melalui injeksi kondisi logika terstruktur.

Solusi Mitigasi Korporat:

1. Gunakan *Parameterized Queries* atau *PreparedStatement* pada JDBC/ASP untuk memisahkan data input dari logika query.
2. Lakukan validasi tipe data ketat pada sisi server (Server-Side Validation) menggunakan prinsip *allow-list*.
3. Terapkan *Principle of Least Privilege* pada user database; hindari penggunaan user 'sa' atau 'db-owner'.

Referensi Standar: OWASP 2021-A03 | CWE-89 | WASC-19

SEDANG Content Security Policy (CSP) Header Not Set

Deskripsi Celah	Header HTTP Content Security Policy (CSP) tidak diimplementasikan pada server. Kondisi ini membuat aplikasi rentan terhadap serangan Cross-Site Scripting (XSS) dan injeksi data berbahaya.
Dampak Sistemik	Mempengaruhi seluruh node utama pada domain target (Status: <i>Systemic</i>).

Solusi Mitigasi Korporat:

Konfigurasi web server, load balancer, atau application gateway untuk menyertakan header Content - Security - Policy yang valid. Deklarasikan sumber daya (JS, CSS, Font) yang terpercaya secara eksplisit guna mencegah eksekusi skrip ilegal.

Referensi Standar: OWASP 2021-A05 | CWE-693 | WASC-15

SEDANG Missing Anti-clickjacking Header (X-Frame-Options)

Deskripsi Celah	Halaman web tidak dilindungi dari serangan Clickjacking karena tidak adanya instruksi X-Frame-Options atau directive frame-ancestors pada CSP. Penyerang dapat membingkai (iframe) situs ini di dalam situs eksternal berbahaya untuk menipu interaksi klik pengguna.
Dampak Sistemik	Terdeteksi di seluruh endpoint aplikasi utama secara menyeluruh (Status: <i>Systemic</i>).

Solusi Mitigasi Korporat:

Tambahkan header X-Frame-Options dengan nilai DENY jika halaman tidak boleh dibingkai sama sekali, atau SAMEORIGIN jika hanya diizinkan untuk domain internal perusahaan.

Referensi Standar: CWE-1021 | WSTG-v42-CLNT-09

| 4. Rangkuman Celah Keamanan Tingkat Rendah (Low Risks) & Sistemik

Berikut adalah tabel parameter teknis untuk kerentanan berkategori Lemah yang bersifat masif/sistemik pada sistem:

Nama Kerentanan	Status / Instance	Dampak Potensial	Rekomendasi Utama
Cookie No HttpOnly Flag	2 Instances	Token sesi (GRUYERE / GRUYERE_ID) dapat diakses via JavaScript (Rentan Session Hijacking).	Aktifkan flag HttpOnly pada setiap proses pembuatan cookie sesi.
Cookie Without Secure Flag	2 Instances	Cookie dikirim melalui saluran tidak enkripsi (HTTP biasa), rentan penyadapan jalur komunikasi.	Wajibkan flag Secure agar cookie hanya ditransmisikan via HTTPS.
Cookie without SameSite Attribute	2 Instances	Rentan terhadap ancaman Cross-Site Request Forgery (CSRF) dan serangan berbasis taktik timing.	Atur atribut SameSite=Lax atau SameSite=Strict secara merata.
Pengungkapan Timestamp - Unix	Systemic	Server membocorkan informasi waktu internal (Unix timestamp) yang memicu deteksi pola data terstruktur.	Pastikan data waktu yang diekspos bukan merupakan data kritikal sistem backend.
Server Leaks Version Info	1 Instance	Header respons HTTP membocorkan arsitektur server (misal: scaffolding on HTTPServer2).	Batasi atau samarkan nilai pada properti header Server menjadi informasi generik.
Strict Transport-Security Missing	Systemic	Koneksi tidak dipaksa menggunakan HTTPS secara default, membuka celah <i>Downgrade Attack</i> .	Implementasikan header HSTS: Strict-Transport-Security pada server produksi.
X-Content-Type-Options Missing	Systemic	Browser dapat melakukan <i>MIME-sniffing</i> , memicu eksekusi file non-eksekutif menjadi skrip aktif.	Tambahkan header global wajib: X-Content-Type-Options: nosniff.

| 5. Temuan Informasional & Jejak Endpoint (Informational Insights)

Berdasarkan pemindaian pasif, tercatat beberapa anomali performa dan pemetaan struktur endpoint. Ditemukan tingginya persentase respons lambat (*Slow Responses*) hingga mencapai **92.9%** pada <https://google-gruyere.appspot.com> dan **100%** pada layanan optimizationguide-pa.googleapis.com. Selain itu, terdeteksi indikasi **Cookie Poisoning** (2 instances) akibat parameter URL input pengguna yang tercermin langsung pada isi cookie, serta **Charset Mismatch** sistemik antara header HTTP (UTF-8) dengan tag META konten (ISO-8859-1).

| 6. Kesimpulan & Penutup

Secara keseluruhan, arsitektur aplikasi yang diuji menunjukkan adanya celah kritikal berupa **SQL Injection** yang memerlukan tindakan perbaikan darurat berskala prioritas tinggi. Selain itu, penataan penguatan keamanan (*security hardening*) pada sisi HTTP Response Headers perlu segera distandarisasi sesuai panduan global korporasi besar guna mencapai kepatuhan standar internasional seperti PCI DSS dan OWASP Top 10.

Demikian laporan penyusunan audit teknis ini kami sampaikan secara formal agar dapat dipergunakan sebagai dasar perbaikan infrastruktur siber perusahaan.

Hormat Kami,
Tim Auditor Independen

(Cyber Security Specialist Team)

Penyusun Teknis / Bug Hunter,
Habib Muzakki

(Alumni MAN 2 Serang / D4 Vokasi TI)